

Proposta de Projeto

Engenharia de Computação – PUCPR

Detecção de Vulnerabilidades em Código-Fonte com Machine Learning

André Fabricio Wozniack – Ricardo Hespanhol Pamplona

Orientador: Prof. Julio Cezar Nievola

1. Motivação para o desenvolvimento do projeto

Com o aumento do uso de Inteligência Artificial para gerar código, trechos produzidos automaticamente vêm sendo incorporados a projetos sem análise adequada de segurança, o que pode introduzir vulnerabilidades como injeção de comandos, vazamento de dados e falhas de gerenciamento de memória.

Estudos recentes indicam que código assistido por IA apresenta, em média, 4,4 vezes mais vulnerabilidades que código escrito apenas por humanos, com certos tipos de falha aparecendo com maior frequência e templates inseguros se repetindo em diferentes repositórios, sugerindo padrões induzidos pelos próprios modelos (State of Cyber, 2026; Wu *et al.*, 2025).

Embora ferramentas de análise estática ajudem a identificar esses problemas, elas frequentemente geram falsos positivos e possuem dificuldade para compreender o contexto do código, como a intenção do desenvolvedor e chamadas entre funções (Yang *et al.*, 2025; TechScience, 2025).

Por isso, há demanda por abordagens mais contextuais, baseadas em Machine Learning e Large Language Models, que vêm sendo aplicadas à detecção de vulnerabilidades e à priorização de alertas em código gerado automaticamente (Wang *et al.*, 2025; MDPI, 2026).

2. Objetivo

O objetivo do projeto é desenvolver um software capaz de analisar novos trechos de código-fonte antes de sua integração ao sistema, identificando padrões e erros comuns que possam resultar em vulnerabilidades de segurança conhecidas.

A solução deverá utilizar técnicas de Machine Learning para auxiliar na identificação e classificação dessas vulnerabilidades, buscando complementar ferramentas tradicionais de análise estática de código.

3. Descrição sucinta das teorias e técnicas utilizadas

O desenvolvimento do projeto envolverá conceitos de segurança de software, análise estática de código e Machine Learning.

Serão estudadas técnicas de classificação de vulnerabilidades, processamento e representação de código-fonte e modelos capazes de identificar padrões associados a falhas de segurança.

Também poderão ser utilizados Large Language Models como apoio à análise contextual do código. A avaliação da solução será realizada por meio de métricas de classificação, como precisão, recall, F1-score e taxa de falsos positivos, comparando os resultados obtidos com ferramentas tradicionais de análise estática.

4. Descrição do hardware e/ou software necessários para o desenvolvimento

Software: Python, Java, Git, Docker, bancos de dados, bibliotecas de Machine Learning e ferramentas de análise de código, como SonarQube, linters e Dependabot.

Também serão utilizados conjuntos de dados contendo exemplos de vulnerabilidades conhecidas para treinamento e avaliação dos modelos.

Hardware: computadores pessoais dos integrantes e, caso necessário, infraestrutura computacional local ou em nuvem para treinamento e execução dos modelos de Machine Learning.

5. Contexto do Projeto

O projeto será desenvolvido como Trabalho de Conclusão de Curso de Engenharia de Computação da PUCPR.

Os integrantes serão responsáveis pelo levantamento bibliográfico, preparação dos dados, desenvolvimento da solução, implementação dos modelos, realização dos experimentos e avaliação dos resultados.

A solução tem como público-alvo desenvolvedores e equipes de desenvolvimento de software que utilizam Inteligência Artificial Generativa para auxiliar na produção de código-fonte.

Referências bibliográficas básicas

MDPI. A Survey on Large Language Models in Software Security: Opportunities and Threats. **Computers**, v. 15, n. 4, 2026. Disponível em: <https://www.mdpi.com/2073-431X/15/4/226>. Acesso em: 1 set. 2026.

STATE OF CYBER. **AI-Assisted Code Introduces 4.4x More Security Vulnerabilities Than Human-Written Code, New Research Finds**. The Tennessean. 20 ago. 2026. Disponível em: <https://www.tennessean.com/press-release/story/223693/ai-assisted-code-introduces-4-4x-more-security-vulnerabilities-than-human-written-code-new-research-finds/>. Acesso em: 1 set. 2026.

TECHSCIENCE. Static Analysis Techniques for Secure Software: A Systematic Review. **Journal of Cyber Security**, v. 7, n. 1, 2025. Disponível em: <https://www.techscience.com/JCS/v7n1/64045/html>. Acesso em: 1 set. 2026.

WANG, Y. *et al.* A Generative AI Cybersecurity Risks Mitigation Model for Code Generation: Using ANN-ISM Hybrid Approach. **Scientific Reports**, 2025. Disponível em: <https://www.nature.com/articles/s41598-025-34350-3>. Acesso em: 1 set. 2026.

WU, Z. *et al.* **AI Code in the Wild: Measuring Security Risks and ...** arXiv. 2025. arXiv: 2512.18567. Disponível em: <https://arxiv.org/abs/2512.18567>. Acesso em: 1 set. 2026.

YANG, X. *et al.* **ZeroFalse: Improving Precision in Static Analysis with LLMs**. arXiv. 2025. arXiv: 2510.02534. Disponível em: <https://arxiv.org/abs/2510.02534>. Acesso em: 1 set. 2026.

Assinatura do orientador